Freelance Hub

Rapport d'audit de sécurité

4 novembre 2026 · Application de gestion des freelances et du CRA mensuel · Version auditée : branche `main`, lots 0 à 6

Aucune vulnérabilité critique ou élevée ne reste ouverte : 16 constats corrigés et vérifiés, 3 risques de dépendances acceptés et justifiés.

0	0	91	16
constat Semgrep restant (156 règles, 131 fichiers)	vulnérabilité critique ou élevée (npm audit)	tests unitaires au vert	tests de bout en bout (accès, a11y) au vert

Périmètre et méthode

- **Périmètre** : code applicatif (pages, Server Actions, Route Handlers, bibliothèques), schéma et migrations PostgreSQL (dont triggers), scripts, configuration, CI.
- **Revue automatique security-guidance** à chaque commit (constat SG-1, prise de compte nOAuth).
- **Revue manuelle** selon OWASP ASVS 4 / Top 10 : authentification, sessions, contrôle d'accès (IDOR), injections, fichiers, en-têtes, secrets, divulgation, déni de service, journalisation, logique métier, chaîne d'approvisionnement.
- **Analyse statique Semgrep 1.182.1** (télémétrie désactivée) : p/owasp-top-ten, p/typescript, p/react, p/nextjs, p/nodejs, p/secrets, p/javascript, p/security-audit — 5 constats initiaux (CI), 0 après correction.
- **npm audit** : 27 avis initiaux (3 élevés, 24 modérés) — 0 élevé après correction.
- **Vérification** des correctifs par tests unitaires, tests de bout en bout et requêtes HTTP ciblées.

Tableau des constats

ID	Constat	Gravité	Statut
SG-1	Prise de compte via Entra ID (nOAuth) — liaison par e-mail security-guidance (revue automatique au commit)	Élevée	Corrigé
F1	Absence d'en-têtes de sécurité (clickjacking, CSP, HSTS) Revue manuelle OWASP ASVS	Moyenne	Corrigé
F2	Pas de limitation de débit sur les traitements coûteux et la page publique Revue manuelle OWASP ASVS	Moyenne	Corrigé
F3	Première liaison SSO sur des claims modifiables Revue manuelle OWASP ASVS	Faible	Corrigé
F4	Routes GET de téléchargement modifiant l'état (CSRF de journalisation) Revue manuelle OWASP ASVS	Faible	Corrigé
F5	Événements de sécurité non journalisés Revue manuelle OWASP ASVS	Faible	Corrigé
F6	Gestion fragile du secret HMAC des codes d'authenticité Revue manuelle OWASP ASVS	Faible	Corrigé
F7	Connexion de démo conditionnée au seul NODE_ENV Revue manuelle OWASP ASVS	Faible	Corrigé

ID	Constat	Gravité	Statut
F8	E-mails : faux succès sans SMTP en production, adresses dans les journaux Revue manuelle OWASP ASVS	Faible	Corrigé
F9	Accès illimité dans le temps d'un manager aux pièces d'un ancien prestataire Revue manuelle OWASP ASVS	Faible	Corrigé
F10	Dates calendaires inexistantes acceptées Revue manuelle OWASP ASVS	Faible	Corrigé
F11	Course entre modification des taux et soumission d'un CRA Revue manuelle OWASP ASVS	Faible	Corrigé
F12	CI : actions non épinglées, jeton en écriture Revue manuelle + Semgrep (5 constats)	Faible	Corrigé
F13	Sessions JWT non révocables Revue manuelle OWASP ASVS	Faible	Corrigé
F14	Données personnelles résiduelles après anonymisation Revue manuelle OWASP ASVS	Info	Corrigé
F15	Données visibles sur /verify ; configuration derrière proxy Revue manuelle OWASP ASVS	Info	Accepté / corrigé
DEP-1	nodemailer < 10.3.1 (GHSA-p6gq-j5cr-w38f et avis liés) npm audit	Élevée (×3)	Corrigé
DEP-2	minimatch (ReDoS) dans l'outillage ESLint npm audit	Modérée (×15)	Accepté
DEP-3	exceljs → archiver / glob / minimatch / uuid npm audit	Modérée (×9, production)	Accepté

Détail des constats et corrections

SG-1 Prise de compte via Entra ID (nOAuth) — liaison par e-mail

Élevée Corrigé security-guidance (revue automatique au commit)

Problème. Le compte applicatif était retrouvé par l'adresse e-mail renvoyée par Entra ID, donnée modifiable et non garantie ; avec un émetteur multi-tenant, un compte d'un autre annuaire pouvait se présenter avec l'e-mail d'un utilisateur.

Correction. Démarrage refusé si l'émetteur n'est pas un tenant précis (common / organizations / consumers rejetés) ; contrôle du claim tid à chaque connexion ; liaison définitive à l'identifiant immuable oid (colonne User.entraOid, unique), l'e-mail ne servant qu'à la première liaison atomique. Règles couvertes par des tests unitaires.

`src/auth.ts, src/lib/auth/entra.ts, migration security_entra_oid`

F1 Absence d'en-têtes de sécurité (clickjacking, CSP, HSTS)

Moyenne Corrigé Revue manuelle OWASP ASVS

Problème. Aucune CSP, frame-ancestors/X-Frame-Options, HSTS, Referrer-Policy ni Permissions-Policy ; une page hostile pouvait encadrer la file de validation et faire cliquer « Tout valider » à un manager connecté.

Correction. En-têtes globaux dans next.config.ts : CSP (frame-ancestors 'none', object-src 'none', base-uri et form-action restreints), X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy, COOP, HSTS en production ; en-tête X-Powered-By supprimé. Vérifié par requête HTTP.

`next.config.ts`

F2 Pas de limitation de débit sur les traitements coûteux et la page publique

Moyenne Corrigé Revue manuelle OWASP ASVS

Problème. Exports mensuels, PDF, Excel, export RGPD et dépôt de signature appelables en boucle (CPU, mémoire, connexions base) ; /verify et la connexion de démo sans limite par IP.

Correction. Limiteur à fenêtre fixe stocké en base (une requête atomique, multi-instances) : PDF/Excel 60 / 10 min, export mensuel 10 / 10 min, RGPD 5 / h, signature 10 / h par utilisateur ; /verify 30 / min et connexion 20 / 5 min par IP. Réponse 429. Vérifié (blocage après dépassement).

`src/lib/rate-limit.ts, routes /api/*, signature-actions.ts, verify/[code]/page.tsx, auth.ts`

F3 Première liaison SSO sur des claims modifiables

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Repli sur preferred_username et acceptation possible d'identités invitées (B2B) pour la première liaison d'un compte non encore lié.

Correction. Plus de repli sur preferred_username ; identités invitées ou fédérées (claim idp) refusées ; le titulaire du compte est prévenu par e-mail de toute liaison et l'événement est journalisé.

`src/auth.ts`

F4 Routes GET de téléchargement modifiant l'état (CSRF de journalisation)

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Un lien depuis un autre site pouvait déclencher des exports (scellement, entrées d'audit trompeuses, coût CPU).

Correction. Les routes de documents refusent les requêtes intersites (Sec-Fetch-Site autre que same-origin / none → 403, journalisé). Vérifié : 403 en intersite, 401 en même origine sans session valide.

`src/lib/documents/http.ts et routes /api/*`

F5 Événements de sécurité non journalisés

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Connexions, refus de connexion, refus d'accès, appels non autorisés au planificateur et déconnexions n'étaient pas tracés.

Correction. Journal « Security » (base + ligne JSON structurée pour la supervision) : LOGIN, LOGIN_DENIED (e-mail masqué), LOGOUT, ACCESS_DENIED, CROSS_SITE_REQUEST_BLOCKED, CRON_UNAUTHORIZED, SSO_LINK.

`src/lib/security-log.ts, auth.ts, dal.ts, http.ts, cron/reminders`

F6 Gestion fragile du secret HMAC des codes d'authenticité

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Chaîne vide non traitée comme absente, repli sur le secret des sessions hors production, minimum de 16 caractères, erreur découverte seulement à la première soumission.

Correction. AUTH_CODE_SECRET ≥ 32 caractères, distinct de AUTH_SECRET, repli limité au développement local ; contrôle de toute la configuration de production au démarrage (instrumentation.ts) : secrets, APP_URL HTTPS, SMTP, CRON_SECRET, SSO.

`src/lib/documents/auth-code.ts, src/instrumentation.ts`

F7 Connexion de démo conditionnée au seul NODE_ENV

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Un environnement partagé lancé en mode développement aurait exposé une connexion sans mot de passe à n'importe quel compte.

Correction. Désactivée par défaut (.env.example), refusée si le SSO est configuré ou si APP_URL n'est pas locale, limitée en débit, avertissement au démarrage.

`src/auth.ts, .env.example`

F8 E-mails : faux succès sans SMTP en production, adresses dans les journaux

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Sans SMTP, l'envoi était compté comme réussi (relances jamais retentées) et les destinataires écrits en clair dans les journaux.

Correction. Échec explicite en production sans SMTP_URL (et démarrage refusé), adresses masquées dans les journaux, STARTTLS exigé sur le port de soumission, délais réseau courts (nodemailer 10).

`src/lib/notify.ts`

F9 Accès illimité dans le temps d'un manager aux pièces d'un ancien prestataire

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Le périmètre manager couvrait tout freelance ayant eu un contrat sur l'une de ses missions, sans limite de date.

Correction. Accès limité aux contrats en cours ou terminés depuis moins de 6 mois (moindre privilège).

`src/lib/queries/referential.ts`

F10 Dates calendaires inexistantes acceptées

Faible Corrigé Revue manuelle OWASP ASVS

Problème. 2026-02-31 était enregistré comme le 3 mars ; 2026-13-01 provoquait une erreur serveur.

Correction. Validation calendaire stricte (aller-retour ISO) pour contrats, PO, missions, pièces, absences et paramètre du planificateur ; tests unitaires.

`src/lib/validation.ts, actions`

F11 Course entre modification des taux et soumission d'un CRA

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Le contrôle « taux figés » et la lecture des taux à la soumission se faisaient hors verrou commun.

Correction. Verrou de la ligne contrat (FOR UPDATE) pris par la soumission et par la modification ; taux relus et gel recontrôlé dans la transaction.

`src/app/(app)/cra/actions.ts, freelances/actions.ts`

F12 CI : actions non épinglées, jeton en écriture

Faible Corrigé Revue manuelle + Semgrep (5 constats)

Problème. Actions GitHub référencées par étiquette modifiable (@v4) ; permissions par défaut du GITHUB_TOKEN.

Correction. Actions épinglées par empreinte de commit, permissions: contents: read.

`.github/workflows/ci.yml`

F13 Sessions JWT non révocables

Faible Corrigé Revue manuelle OWASP ASVS

Problème. Un jeton volé restait valable 8 h ; la déconnexion ne faisait qu'effacer le cookie.

Correction. Version de session en base vérifiée à chaque requête, incrémentée à la déconnexion et à la désactivation ; expiration après 2 h d'inactivité (renouvellement toutes les 15 min).

`src/auth.ts, src/lib/auth/dal.ts, sidebar.tsx, migration security_hardening`

F14 Données personnelles résiduelles après anonymisation

Info Corrigé Revue manuelle OWASP ASVS

Problème. Identifiant Entra, e-mail dans le journal d'audit et commentaires des jours conservés après anonymisation.

Correction. Anonymisation complétée (oid, sessions, commentaires, charge utile d'audit) ; suppression de fichiers soumise à la même validation de clé que le stockage applicatif.

`scripts/retention.ts, src/lib/storage-keys.ts`

F15 Données visibles sur /verify ; configuration derrière proxy

Info Accepté / corrigé Revue manuelle OWASP ASVS

Problème. La page publique affiche nom, mission, PO et montant au détenteur d'un code (clé de 50 bits, conforme au besoin métier) ; AUTH_URL / AUTH_TRUST_HOST non documentés ; liste des CRA non bornée au périmètre pour un éventuel nouveau rôle.

Correction. Affichage conservé (besoin de vérification par la comptabilité, limité en débit) ; variables documentées ; liste des CRA bornée par timesheetScope.

`verify/[code]/page.tsx, .env.example, src/lib/queries/cra.ts`

DEP-1 nodemailer < 10.3.1 (GHSA-p6gq-j5cr-w38f et avis liés)

Élevée (×3) Corrigé npm audit

Problème. Contournement de disableFileAccess via l'option raw et resolveContent (fonctions non utilisées par l'application, messages texte uniquement).

Correction. Passage à nodemailer 10.3.1 (override explicite, la dépendance optionnelle de next-auth ne sert qu'au fournisseur e-mail non utilisé).

`package.json, src/lib/notify.ts`

DEP-2 minimatch (ReDoS) dans l'outillage ESLint

Modérée (×15) Accepté npm audit

Problème. Déni de service par motif glob dans des outils de développement uniquement (lint), jamais exécutés en production ni sur une entrée utilisateur.

Correction. Risque accepté ; mise à jour à suivre avec la prochaine version majeure d'eslint-config-next.

`devDependencies`

DEP-3 exceljs → archiver / glob / minimatch / uuid

Modérée (×9, production) Accepté npm audit

Problème. minimatch : motifs glob jamais fournis par un utilisateur (génération en mémoire) ; uuid : défaut de bornes uniquement si un tampon est passé, exceljs appelle uuid.v4() sans tampon.

Correction. Non exploitable dans l'usage de l'application ; à suivre (mise à jour d'exceljs ou remplacement) — Dependabot recommandé.

`exceljs`

Contrôles vérifiés

- Contrôle d'accès côté serveur sur chaque page (requireRole), Server Action et Route Handler, avec périmètre par enregistrement (IDOR) : freelance = ses données, manager = ses missions, finance = lecture.
- Rôle et statut actif relus en base à chaque requête ; connexion SSO limitée au tenant de l'entreprise, liaison par oid.
- Verrouillage des CRA soumis et validés en base (triggers PostgreSQL) : même une requête SQL directe ou un bug applicatif ne peut altérer un CRA validé ; seule exception, la purge de rétention.
- Codes d'authenticité HMAC-SHA256 sur un instantané figé du document, comparés à temps constant, recalculés depuis la base à la vérification (falsification détectée, PDF provisoire remplacé reconnu).
- Requêtes SQL brutes exclusivement paramétrées (gabarits Prisma), aucune variante Unsafe en production ; aucun dangerouslySetInnerHTML.
- Fichiers : clés générées par le serveur, chemin confiné, type réel vérifié sur le contenu, signature réencodée (sharp, 16 Mpx max), pièces servies en pièce jointe avec nosniff et CSP sandbox, quotas de dépôt.
- En-têtes Content-Disposition et e-mails assainis (ASCII, retours chariot supprimés) ; Excel en cellules texte (pas d'évaluation de formule).
- Server Actions protégées par le contrôle d'origine de Next ; cookies de session HttpOnly SameSite=Lax ; pas de redirection ouverte.
- Données transmises au navigateur réduites aux champs affichés (pas d'e-mail, de clé de stockage, de budget ni de charge utile d'audit).
- Planificateur protégé par secret comparé à temps constant ; relances idempotentes (contrainte d'unicité).
- Aucun secret dans le dépôt, aucune variable NEXT_PUBLIC_ ; .env et stockage exclus de git ; seed et tests de bout en bout refusent toute base contenant des comptes réels.
- Accessibilité vérifiée automatiquement (axe-core, WCAG 2.1 AA) sur chaque écran dans la suite de bout en bout.

Risques résiduels et recommandations

Domaine	Recommandation
Avant mise en production	Test d'intrusion externe sur l'environnement de recette ; configuration du tenant Entra (invités, claim xms_edov) revue avec l'équipe identité.
Base de données	Purge de rétention sous un rôle PostgreSQL dédié ; retirer TRUNCATE et la modification des fonctions au rôle applicatif.

Domaine	Recommandation
Réseau	Reverse proxy / WAF avec limitation par IP en amont ; TLS 1.2+ ; AUTH_URL et AUTH_TRUST_HOST renseignés.
CSP	Passer à une CSP à nonce (script-src sans 'unsafe-inline') lorsque le coût du rendu dynamique est acceptable.
Dépendances	Activer Dependabot / npm audit en CI ; suivre exceljs (DEP-3) et eslint-config-next (DEP-2).
Secrets	Coffre-fort (Key Vault) pour AUTH_SECRET, AUTH_CODE_SECRET, CRON_SECRET et SMTP ; rotation documentée (la rotation d'AUTH_CODE_SECRET invalide les codes déjà émis : à planifier).
Supervision	Alertes sur les événements LOGIN_DENIED, ACCESS_DENIED, CROSS_SITE_REQUEST_BLOCKED et CRON_UNAUTHORIZED répétés.

Reproduire l'analyse

```
docker run --rm -v "$PWD:/src:ro" -w /src semgrep/semgrep semgrep scan --metrics off \
  --config p/owasp-top-ten --config p/typescript --config p/react --config p/nextjs \
  --config p/nodejs --config p/secrets --config p/javascript --config p/security-audit
npm audit && npm audit --omit=dev
E2E_DATABASE_URL=postgresql://…/freelancehub_e2e npm run test:e2e
```